Figure 25.4 An alternative architecture involves using a central identity provider to handle all the authentication and user management for the system. Tokens are passed back and forth among the identity provider, apps, and APIs.

Instead of signing in to an app directly, the app redirects to an identity provider. The user signs in to this identity provider, which passes *bearer tokens* back to the client (a browser or mobile app, for example) to indicate who the user is and what they're allowed to access. The client can pass these tokens to the APIs to provide information about the logged-in user without needing to reauthenticate or manage users directly in the API.

DEFINITION *Bearer tokens* are strings that contain authentication details about a user or app. They may or may not be encrypted but are typically signed to avoid tampering. JWTs are the most common format. We'll look more at JWTs in section 25.2.

Using a separate identity provider is clearly more complicated on the face of it, as you've thrown a whole new service into the mix, but in the long run this has several advantages:

- *Users can share their identity among multiple services*. As you're logged in to the central identity provider, you're essentially logged in to all apps that use that service. This gives you the single-sign-on experience, where you don't have to keep logging in to multiple services.
- *You don't need to duplicate sign-in logic between multiple services*. All the sign-in logic is encapsulated in the identity provider, so you don't need to add sign-in screens to all your apps.